Case study based — not a real client engagement

Cybersecurity Risk Assessment Report

RetailNova Pty Ltd — Asset, Threat & Risk Analysis

Field	Detail
Client	RetailNova Pty Ltd — retail, consumer electronics & lifestyle products (AU)
Headquarters	Melbourne, Australia
Scope	Enterprise IT, e-commerce, POS, cloud, and third-party ecosystem
Report Type	Organisational Cybersecurity Risk Assessment
Date Prepared	30 July 2026
Prepared By	Jamal Bekkouche-Henrys
Audience	Executive Team & Risk Committee
Classification	TLP:CLEAR — Public (case study)

1. Executive Summary

RetailNova Pty Ltd operates a large, distributed retail environment spanning 85 physical stores, a custom-built e-commerce platform, and a mobile application, underpinned by enterprise platforms including Salesforce, SAP, and AWS. This diversity of systems, combined with extensive third-party integrations for payments, logistics, marketing, and loyalty programs, creates a broad attack surface that must be actively managed.

This report presents a structured risk assessment of RetailNova's information assets, the threats most likely to target a retail organisation of this profile, and the vulnerabilities that could allow those threats to materialise. The assessment draws on the organisation's asset base, its history of security incidents (2023 phishing/credential compromise, 2024 attempted ransomware, 2025 third-party data leak), and its current control environment (RBAC, BYOD with VPN, basic awareness training, firewalls, and antivirus).

Overall, RetailNova's risk posture is assessed as Medium-High. Core risks cluster around: (1) payment card and customer data exposure across a large e-commerce and POS estate; (2) third-party and supply-chain risk, evidenced by the 2025 vendor data leak; (3) identity and remote-access risk arising from BYOD and VPN use without confirmed strong authentication; and (4) the organisation's demonstrated but incomplete resilience to ransomware. Section 5 provides a prioritised risk register, and Section 7 sets out recommendations to reduce risk to an acceptable level.

2. Organisational Asset Overview

An accurate asset inventory is the foundation of risk assessment. The following categorises RetailNova's key information assets by type, based on the information provided, to support the threat and risk analysis in later sections.

2.1 Digital & Application Assets

Asset	Description	Criticality
E-commerce website	Custom-built platform handling online retail sales	Critical
Mobile application	Customer-facing app, likely linked to loyalty and purchasing	High

Asset	Description	Criticality
Payment gateway integrations	PayPal and Afterpay integrations for transaction processing	Critical
POS systems	Cloud-connected point-of-sale across 85 stores	Critical
Salesforce (CRM)	Customer relationship management and customer data	High
SAP (ERP)	Inventory, finance, and HR operations	Critical
AWS cloud environment	Hosting for core infrastructure and applications	Critical
Microsoft Teams / Slack	Internal corporate communications	Medium

2.2 Data Assets

Data Category	Sensitivity & Notes
Customer PII (names, emails, phone, address)	High sensitivity; subject to Australian Privacy Act obligations
Tokenised payment details	High sensitivity; PCI DSS-relevant even though tokenised
Purchase history & behavioural analytics	Medium-high sensitivity; commercially valuable, profiling risk
Loyalty program data	Medium sensitivity; often linked to PII and purchase behaviour
Employee HR & payroll data (via SAP)	High sensitivity; personal and financial information
Corporate/internal communications	Medium sensitivity; may contain confidential business data

2.3 Infrastructure & People Assets

- Cloud infrastructure: AWS-hosted environment supporting core applications and data storage.
- Network: corporate network plus VPN-based remote access for staff.
- Endpoints: corporate-issued and BYOD devices used by approximately 1,200 employees.
- Third-party ecosystem: logistics, marketing, and loyalty program vendors with system or data access.
- Physical retail estate: 85 stores nationwide, each with networked POS terminals.
- Workforce: staff across corporate, customer service, and retail store roles, with role-based access control (RBAC) governing system access.

3. Threat Landscape

Retailers of RetailNova's size and profile are attractive targets due to the volume of payment and personal data processed, the complexity of their third-party ecosystems, and the operational impact of disruption during peak trading periods. Relevant threat actor categories include:

Threat Actor	Motivation	Typical Techniques Relevant to RetailNova
Organised cybercrime groups	Financial gain (ransomware, card fraud, data resale)	Phishing, ransomware, credential theft, POS/payment data targeting
Opportunistic attackers	Financial gain, low-effort targets	Credential stuffing, exploitation of known vulnerabilities, scanning for exposed services
Malicious/negligent insiders	Financial gain, grievance, or human error	Data exfiltration, misuse of RBAC privileges, accidental data exposure

Threat Actor	Motivation	Typical Techniques Relevant to RetailNova
Third-party/supply-chain compromise	Varies — often a stepping stone to the primary target	Compromise of marketing, logistics, or loyalty vendors with data or system access
Hacktivists	Ideological/reputational disruption	Website defacement, DDoS, public data leaks

3.1 Relevance of Past Incidents

RetailNova's own incident history is directly indicative of the threats most likely to recur and should heavily weight the risk register in Section 5:

Year	Incident	Threat Insight
2023	Phishing attack on customer service representatives; credential compromise	Confirms social engineering is an effective initial access vector against customer-facing staff, who often have access to CRM/customer data.
2024	Attempted ransomware; blocked by endpoint protection, 2-hour downtime	Confirms ransomware operators are actively targeting RetailNova; existing controls partially effective but not sufficient to prevent all business impact.
2025	Third-party marketing vendor data leak; 5,000 customer emails exposed	Confirms third-party/supply-chain risk is a realised, not merely theoretical, concern for the organisation.

4. Risk Assessment Methodology

Risks are assessed using a standard Likelihood × Impact model, each rated on a 1–5 scale, producing a combined risk rating of Low, Medium, High, or Critical as shown below. Likelihood reflects the probability of the threat exploiting the vulnerability within a 12-month period, informed by industry threat intelligence and RetailNova's own incident history. Impact reflects the combined financial, operational, legal, and reputational consequences to the organisation.

Likelihood \ Impact	Low (1-2)	Medium (3)	High (4-5)
Low (1-2)	**Low**	**Low**	**Medium**
Medium (3)	**Low**	**Medium**	**High**
High (4-5)	**Medium**	**High**	**Critical**

5. Risk Register

The following register identifies the key risks facing RetailNova, mapped to affected assets, contributing vulnerabilities, and an overall risk rating. Risks are ordered by rating, from highest to lowest priority.

ID	Risk	Key Vulnerability / Driver	Affected Asset(s)	Rating
R1	Ransomware attack causing extended operational downtime or data loss	Prior attempted ransomware (2024); reliance on endpoint protection as primary control; unconfirmed backup isolation	POS, corporate endpoints, SAP, AWS	**Critical**
R2	Compromise of payment/card data across e-commerce or POS environment	Large payment-processing footprint (PayPal, Afterpay, POS); high attacker financial incentive	E-commerce platform, POS, payment gateways	**Critical**

ID	Risk	Key Vulnerability / Driver	Affected Asset(s)	Rating
R3	Phishing/social engineering leading to credential compromise	Realised in 2023; customer service staff have CRM access; awareness training described as "basic"	Salesforce, staff credentials, VPN access	**High**
R4	Third-party/vendor data breach exposing customer data	Realised in 2025; multiple third-party integrations (logistics, marketing, loyalty) without stated vendor security assurance process	Customer PII, loyalty data	**High**
R5	Unauthorised access via compromised BYOD or VPN endpoint	BYOD policy with remote VPN access; device security standards not specified	Corporate network, internal systems	**High**
R6	Cloud misconfiguration in AWS environment leading to data exposure	Large, complex AWS footprint; configuration/monitoring controls not detailed	AWS-hosted applications and data	**High**
R7	Insider misuse or accidental data exposure	RBAC in place but insider risk not addressed by technical controls alone; large workforce (1,200 staff)	Salesforce, SAP, customer/employee data	**Medium**
R8	Business email compromise (BEC) targeting finance or executive staff	High-revenue retail business is a common BEC target; no mention of email authentication (DMARC/DKIM/SPF) or payment verification controls	Finance systems, corporate email	**Medium**
R9	Website/application-layer attack (e.g., SQL injection, credential stuffing) against e-commerce platform	Custom-built e-commerce platform; no mention of WAF, secure SDLC, or regular penetration testing	E-commerce website, mobile app	**Medium**
R10	Denial-of-service disruption during peak trading periods	High-profile retail brand with seasonal peak-trading reliance on availability	E-commerce platform, AWS infrastructure	**Medium**
R11	Non-compliance with Australian Privacy Act / PCI DSS obligations	Broad collection of PII and payment-related data without confirmed compliance program details	All customer data assets	**Medium**
R12	Physical security risk to in-store POS terminals (tampering, skimming)	85 physical retail locations with POS hardware	POS systems	**Low**

6. Key Risk Areas — Detailed Analysis

6.1 Payment and E-Commerce Ecosystem

RetailNova's payment ecosystem spans a custom e-commerce platform, a mobile app, in-store POS terminals, and integrations with PayPal and Afterpay. Even with tokenisation in place, the surrounding environment — including the e-commerce application layer, POS network, and supporting infrastructure — remains a high-value target, since a compromise upstream of tokenisation (e.g., at the point of capture) can still expose card data. The scale of this footprint (85 stores plus online) increases both the attack surface and the potential blast radius of any single compromise.

6.2 Third-Party and Supply-Chain Risk

The 2025 marketing vendor data leak demonstrates that RetailNova's risk exposure extends beyond its own infrastructure to its ecosystem of logistics, marketing, and loyalty program partners. Without a formal third-party risk management program — including security due diligence, contractual data-protection requirements, and ongoing monitoring — RetailNova has limited visibility or control over how these vendors protect shared customer data.

6.3 Identity, Remote Access, and BYOD

The combination of BYOD and VPN-based remote access broadens the attack surface beyond corporate-managed infrastructure. Personal devices may have inconsistent patching, endpoint protection, or configuration standards, and if authentication to VPN and core systems does not consistently enforce multi-factor authentication (MFA), a single set of compromised credentials — as occurred in the 2023 phishing incident — could provide an attacker with broad internal access.

6.4 Cloud Environment (AWS)

AWS underpins a significant share of RetailNova's infrastructure. Cloud environments of this scale commonly carry risk from misconfiguration (e.g., overly permissive storage or identity policies), insufficient logging and monitoring, and unclear division of security responsibility between RetailNova and AWS under the shared responsibility model. The absence of stated cloud security posture management (CSPM) or continuous configuration monitoring is a material gap given the criticality of the workloads hosted there.

6.5 Human Factors and Security Culture

Two of RetailNova's three reported incidents (2023 phishing, arguably compounded by human factors in 2024's near-miss) trace back to human-layer weaknesses. "Basic" security awareness training suggests the current program may not be tailored to high-risk roles (customer service, finance) or reinforced through regular simulated phishing and measurable outcomes.

7. Recommendations

Recommendations are prioritised against the risk register in Section 5, focusing first on risks rated Critical and High.

7.1 Immediate / High-Priority (0–3 months)

- Validate and test ransomware resilience: confirm backups are immutable/offline and regularly test full restoration; formally document and rehearse the incident response plan given the 2024 near-miss.
- Enforce multi-factor authentication (MFA) across VPN, Salesforce, SAP, AWS administrative access, and all remote access pathways.
- Commission a PCI DSS gap assessment and, where applicable, a penetration test of the e-commerce platform, mobile app, and POS environment, given the criticality of payment data.
- Establish a formal third-party risk management process, including security questionnaires, contractual data-protection clauses, and periodic assurance reviews for logistics, marketing, and loyalty vendors.
- Uplift security awareness training for customer service and finance teams specifically, incorporating regular simulated phishing exercises with measurable improvement targets.

7.2 Short-Term (3–6 months)

- Implement a cloud security posture management (CSPM) capability across the AWS environment, including automated detection of misconfigurations and excessive permissions.

- Deploy a Web Application Firewall (WAF) and strengthen the secure software development lifecycle (SDLC) for the custom-built e-commerce platform and mobile app.
- Define and enforce minimum security standards for BYOD devices (e.g., mobile device management, encryption, patch compliance) as a condition of VPN and system access.
- Implement DMARC, DKIM, and SPF email authentication, along with out-of-band verification procedures for finance/payment instruction changes, to reduce business email compromise risk.
- Extend logging and monitoring (SIEM/MDR) coverage across POS, cloud, and corporate network environments to reduce detection and response time.

7.3 Medium-Term (6–12 months)

- Formalise an enterprise risk management framework aligned to a recognised standard (e.g., ISO/IEC 27001 or the Essential Eight), with regular reassessment of this risk register.
- Conduct a data mapping and minimisation exercise across CRM, ERP, and analytics platforms to reduce the volume of sensitive data at risk.
- Establish insider risk monitoring (e.g., data loss prevention tooling) proportionate to the sensitivity of customer, payment, and employee data accessible under RBAC.
- Review physical security and anti-tampering controls for in-store POS terminals across the 85-store network.
- Undertake regular (at least annual) independent penetration testing and red-team exercises covering e-commerce, POS, cloud, and third-party integration points.

8. Conclusion

RetailNova's growth into a large, digitally integrated retail business has brought commensurate growth in cyber risk. The organisation's own incident history — spanning phishing-driven credential compromise, an attempted ransomware attack, and a third-party data leak — provides a clear and specific basis for prioritising the risks identified in this report, rather than relying solely on generic industry threat data. The highest-priority risks relate to ransomware resilience, payment and e-commerce security, and third-party data handling. Addressing the recommendations in Section 7, particularly the immediate-priority items, will materially reduce RetailNova's overall risk exposure and support compliance with its data protection obligations.

This report reflects a point-in-time assessment based on information provided and should be revisited periodically, and following any material change to RetailNova's technology environment or threat landscape.